

Blatt 13

Software Qualität

Nichtfunktionale Tests – Sicherheitstests

Luis Staudt

Aufgabe 1: Sicherheitstests

Im Folgenden werden die sieben Leitfragen für die Testart **Sicherheitstests** beantwortet. Grundlage ist Kapitel 18 aus Bath/McKay, "Praxiswissen Softwaretest – TestAnalyst und Technical Test Analyst".

1. Adressiertes Qualitätsmerkmal nach ISO/IEC 25010

Sicherheitstests adressieren das Qualitätsmerkmal **Sicherheit (Security)**. Es beschreibt die Fähigkeit der Software, unberechtigten Zugriff – sowohl versehentlich als auch vorsätzlich – auf Programme und Daten zu verhindern. Nach ISO/IEC 25010 gliedert es sich in die Teilmerkmale:

- **Vertraulichkeit** – Daten sind nur Befugten zugänglich,
- **Integrität** – Schutz vor unbefugtem Ändern/Löschen von Daten,
- **Nichtabstreitbarkeit** – durchgeführte Aktionen sind nachweisbar,
- **Zurechenbarkeit** – Aktionen lassen sich einem Akteur zuordnen,
- **Authentizität** – die Identität eines Akteurs ist nachweisbar.

2. Ziele der Testart

- Sicherheitslücken und Schwachstellen aufdecken, *bevor* ein Angreifer sie ausnutzen kann.
- Schutz wertvoller Informationen (z. B. Kreditkartendaten, Benutzerprivilegien) vor dem Zugriff Unbefugter nachweisen.
- Zeigen, dass das System den typischen Bedrohungen standhält (Devise: "Kenne deinen Feind").
- Im Unterschied zu funktionalen Tests liegt der Fokus nicht auf der vorgesehenen Funktion, sondern auf den "anderen Dingen", die ein System nebenbei tun kann und die sich ausnutzen lassen.

3. Allgemeine Vorgehensweise, Varianten und Unterarten

Eine gute Vorgehensweise kombiniert statische und dynamische Verfahren über den gesamten Lebenszyklus; sie ist kein bloßes "Hacking". Eingesetzt werden:

- **Technische Reviews** der Dokumente (Sicherheitsstrategie, Systemarchitektur) anhand einer Sicherheits-Checkliste.
- **Statische Codeanalyse** (werkzeuggestützt) am erstellten Code.
- **Dynamische Analyse** während der Codeausführung.
- **Gezielte Angriffe** auf identifizierte Schwachstellen.

Geplante Angriffe folgen nach Whittaker & Thompson drei Schritten: (1) Sammeln sicherheitsrelevanter Informationen, (2) Scannen auf Schwachstellen, (3) Entwicklung und Durchführung der Angriffe. Statt der Standard-Testdatenauswahl wird ein "handgemachter" Ansatz verfolgt, der gezielt auf die untersuchte Schwachstelle zugeschnitten ist (u. a. negative Äquivalenzklassen, Ursache-Wirkungs-Graphen für Rechteeregeln, explorative Tests).

Wichtige Bedrohungs-Unterarten (zu testende Lücken): Eingabepufferüberlauf, Nebeneffekte zugelassener Funktionen, unbefugtes Kopieren/Löschen von Daten (SQL-Injection), unbefugter Zugang, Missbrauch von Benutzerrechten, Denial-of-Service, Abfangen/Ändern von Übertragungen (Man-in-the-Middle), Knacken von Verschlüsselung, Logikbomben/Ostereier, Cross-Site-Scripting (XSS) und Phishing.

4. Erhobene Qualitätsmetriken bzw. Kennzahlen

- Anzahl gefundener Schwachstellen, gegliedert nach Bedrohungskategorie.
- Schweregrad der Lücken (z. B. CVSS-Score) und Anzahl bekannter, ungepatchter Schwachstellen (Abgleich mit CVE).
- Erfolgsquote der durchgeführten Angriffe.
- Abdeckung der Bedrohungskategorien bzw. der Sicherheits-Checkliste.
- Rückverfolgbarkeit: lückenlose Zuordnung von identifizierter Schwachstelle → durchgeführtem Test → Ergebnis.

5. Schwierigkeiten und deren Adressierung

- **Schwer erkennbare Symptome:** Sicherheitsmängel zeigen sehr unterschiedliche Symptome. → Erfahrene Tester mit Spezialwissen und Kreativität, kein reines Standardvorgehen.
- **Repräsentative Testdaten:** sind aufwendig zu erstellen (z. B. verschlüsselte Daten, Trustcenter); explorative Tests werden dadurch eingeschränkt. → frühzeitige Planung der Testumgebung und -daten.
- **Destruktivität:** Angriffe können Daten/System beschädigen. → vor Durchführung sicherstellen, dass die Testumgebung wiederherstellbar ist.
- **Rechtlich/ethisch:** ohne Erlaubnis können Tests als echte Angriffe gedeutet werden (Strafbarkeit). → Erlaubnis der Geschäftsführung einholen, alle Beteiligten informieren; Tester melden Lücken, statt sie auszunutzen.
- **Vertraulichkeit der Ergebnisse:** → Berichte nur an kleinen Empfängerkreis, separates Fehlerverfolgungssystem, verschlüsselte Übertragung.
- **Sich ständig ändernde Bedrohungslage:** → Werkzeuge und Wissen laufend aktualisieren, Betriebsphase mit Überwachung einbeziehen.

6. Typischerweise eingesetzte Werkzeuge

- Statische Sicherheitsprüfwerkzeuge, z. B. **Fortify Source Code Analysis**; vom Hersteller laufend an neue Bedrohungen angepasst.
- Werkzeuge zur Simulation von Ausnahmebedingungen des Betriebssystems, z. B. **Holodeck**.
- Werkzeuge zur Erzeugung sehr langer Strings (Test auf Pufferüberläufe).
- Schwachstellenscanner sowie Wissensquellen wie **CVE**, **OWASP** und **NIST**.

7. Praktische Anwendung bei “Schwarzwald-Entdecker”

Anwendung. “Schwarzwald-Entdecker” ist ein Web-Portal, über das Kunden Ausflüge planen, buchen und *bezahlen* sowie ihre Buchungen einsehen, ändern und stornieren. Es verarbeitet personenbezogene Daten (DSGVO) und Zahlungsdaten – damit ist Sicherheit ein zentrales Qualitätsziel.

Lebenszyklus-Vorgehen. Zuerst Review der Sicherheitsstrategie und der Architektur (Protokolle, Verschlüsselung, Rechtekonzept), dann statische Codeanalyse, danach – mit Erlaubnis der Geschäftsführung – gezielte Angriffe gegen eine wiederherstellbare Testumgebung.

Beispielhafte Angriffe je Bedrohung:

- **Pufferüberlauf / XSS:** überlange Strings und Skript-Eingaben in Registrierungs- und Login-Formulare einschleusen (negative Äquivalenzklassen).
- **SQL-Injection:** im Such-/Filterfeld des Ausflug-Konfigurators Datenbankbefehle statt Suchbegriffe eingeben.
- **Missbrauch von Benutzerrechten:** prüfen, dass Kunde A die Buchungen von Kunde B nicht einsehen, ändern oder stornieren kann – alle Rechte-Kombinationen testen.
- **Unbefugter Zugang / Vertraulichkeit:** Login-Daten und Kreditkartendaten dürfen nicht “geknackt” oder unverschlüsselt übertragen werden (HTTPS prüfen).
- **Man-in-the-Middle:** versuchen, die Kommunikation während der Zahlung abzufangen und zu verändern.
- **Denial-of-Service:** das öffentlich erreichbare Buchungsportal mit Überlast belasten.
- **Phishing:** gefälschte Login-Seite als Köder für Zugangsdaten.

Berichterstattung. Gefundene Lücken werden vertraulich und rückverfolgbar an einen kleinen Empfängerkreis gemeldet, statt sie auszunutzen.